

CVE & Dependency Findings Report

Project: vulnerable-invoice-service · Scan date: 2026-06-26 · SHA: 61ed8c3

Summary

Severity	Count
CRITICAL	3
HIGH	5
MEDIUM	2
LOW	0
Total findings	10

Scanners: Gripe 0.114.0 (primary, 68 raw matches), Syft 1.45.1 (SBOM generation). OWASP Dependency-Check 9.2.0 ran but NVD data cache was unavailable in this environment; Gripe used as the authoritative CVE source.

Supply-Chain Flags

- TYPOSQUATTED DEPENDENCY** — `com.fastxml.jackson.core:jackson-databind:2.9.8` is declared in `pom.xml`. The groupId is missing the letters `er` from `fasterxml`, impersonating the legitimate `com.fasterxml.jackson.core`. This coordinate does not exist on Maven Central and was blocked by Maven 3.8's HTTP mirror blocker. Remove immediately — confirmed supply-chain malware injection vector pattern.
- UNTRUSTED REPOSITORY** — `http://insecure-mirror.example.net/maven2` is declared as `internal-untrusted-mirror` in `<repositories>`. Plain HTTP over an unverified host is susceptible to MITM artifact substitution. Maven 3.8+ blocks this by default (exit code 1 confirmed). Remove or replace with an authenticated HTTPS endpoint.

CVE Findings

CRITICAL `org.apache.logging.log4j:log4j-core:2.14.1`

Field	Value
Coordinate	<code>org.apache.logging.log4j:log4j-core:2.14.1</code>
Scope	compile (direct)
Advisories	7 (GHSA + CVE)
Max CVSS	10.0 (Critical)
Key CVEs	CVE-2021-44228, CVE-2021-45046, CVE-2021-44832, CVE-2021-45105, CVE-2025-68161
Fix	Upgrade to 2.17.1

CVE-2021-44228 (Log4Shell) — CVSS 10.0. Remote code execution via JNDI lookup injection in log message content. Actively exploited in the wild since December 2021. `log4j-core` is directly imported in `DiscountCalculator.java` — a billing/invoice class that logs user-controlled input.

CVE-2021-45046 — CVSS 9.0. Incomplete fix for Log4Shell; Thread Context Map lookup still exploitable under certain configurations.

CVE-2021-45105 — CVSS 8.6. Denial of service via infinite recursion in self-referential `${ctx:...}` lookups.

CVE-2021-44832 — CVSS 6.6. Arbitrary code execution via attacker-controlled JDBC appender configuration.

CRITICAL [org.apache.logging.log4j:log4j-api:2.14.1](#)

Field	Value
Coordinate	<code>org.apache.logging.log4j:log4j-api:2.14.1</code>
Scope	compile (direct)
Advisories	2 (shared family)
Max CVSS	10.0 (Critical)
Key CVEs	CVE-2021-44228, CVE-2021-45046
Fix	Upgrade to 2.17.1 (must be upgraded together with <code>log4j-core</code>)

Companion API library sharing the Log4Shell vulnerability family. Must be upgraded in lockstep with `log4j-core`.

CRITICAL [com.fasterxml.jackson.core:jackson-databind:2.9.8](#)

Field	Value
Coordinate	<code>com.fasterxml.jackson.core:jackson-databind:2.9.8</code>
Scope	compile (direct)
Advisories	55 advisories
Max CVSS	9.8 (Critical)
Key CVEs	CVE-2019-12086, CVE-2019-12384, CVE-2019-12814, CVE-2019-14379, CVE-2019-14439
Fix	Upgrade to 2.18.8 (latest stable)

55 known advisories covering deserialization gadget-chain RCE, information disclosure, and DoS. Version 2.9.8 was released in 2019 — over 6 years behind current. Many CVEs allow unauthenticated RCE when polymorphic type handling (`enableDefaultTyping`) is active.

HIGH [mysql:mysql-connector-java:8.0.30](#)

Field	Value
Coordinate	<code>mysql:mysql-connector-java:8.0.30</code>
Scope	compile (direct)
Advisories	1 advisory
Max CVSS	8.9 (High)
Key CVEs	CVE-2023-22102
Fix	No fix version detected; migrate to <code>com.mysql:mysql-connector-j</code>
License	GPL-2.0 — policy violation

CVE-2023-22102 — CVSS 8.9. Allows unauthenticated network attackers to compromise MySQL Connectors, affecting confidentiality, integrity, and availability.

LICENSE VIOLATION — `mysql-connector-java` is distributed under GPL-2.0. Inclusion in this permissive-licensed project violates the project's license policy. Migrate to `com.mysql:mysql-connector-j` (GPL with FOSS exception) or a permissively-licensed JDBC driver such as MariaDB Connector/J (LGPL).

HIGH commons-io:commons-io:2.4

Field	Value
Coordinate	commons-io:commons-io:2.4
Scope	compile (direct)
Advisories	2 advisories
Max CVSS	8.7 (High)
Key CVEs	CVE-2021-29425, CVE-2024-47554
Fix	Upgrade to 2.14.0

CVE-2024-47554 — CVSS 8.7. Denial of service via uncontrolled resource consumption in `org.apache.commons.io.input.ClassLoaderObjectInputStream`.

CVE-2021-29425 — CVSS 4.8. Path traversal via `FileNameUtils.normalize()` — partial mitigation only.

HIGH com.fastxml.jackson.core:jackson-databind:2.9.8 (Typosquat)

Field	Value
Coordinate	com.fastxml.jackson.core:jackson-databind:2.9.8
Issue Type	TYPOSQUATTED
Severity	HIGH
Fix	Remove from <code>pom.xml</code> immediately

TYPOSQUATTED — groupId `com.fastxml.jackson.core` does not exist on Maven Central. The name deviates from the legitimate `com.fasterxml.jackson.core` by omitting the letters `er`. This is a textbook typosquatting pattern used to deliver malicious code to developers who mistype coordinates. Maven 3.8 blocked the HTTP lookup. Remove this declaration immediately.

HIGH repository:internal-untrusted-mirror (Untrusted Repository)

Field	Value
Repository ID	internal-untrusted-mirror
URL	<code>http://insecure-mirror.example.net/maven2</code>
Issue Type	UNTRUSTED_REPO
Severity	HIGH
Fix	Remove <code><repository></code> block from <code>pom.xml</code>

UNTRUSTED HTTP REPOSITORY — Plain HTTP over an unverified external host. All artifacts resolved from this mirror could be silently substituted by a MITM attacker at the network level. Maven 3.8+ blocks such mirrors by default (confirmed: build fails with `maven-default-http-blocker` error). Remove this repository declaration entirely; if a private mirror is needed, use an authenticated HTTPS Nexus or Artifactory instance.

MEDIUM `org.apache.commons:commons-lang3:3.4`

Field	Value
Coordinate	<code>org.apache.commons:commons-lang3:3.4</code>
Scope	compile (direct)
Advisories	1 advisory
Max CVSS	6.5 (Medium)
Key CVEs	CVE-2025-48924
Fix	Upgrade to 3.18.0

CVE-2025-48924 — CVSS 6.5. Improper input validation. Version 3.4 was released in 2015 — over 9 years outdated.

MEDIUM `com.google.guava:guava:24.1.1-jre`

Field	Value
Coordinate	<code>com.google.guava:guava:24.1.1-jre</code>
Scope	compile (direct)
Advisories	2 advisories
Max CVSS	5.5 (Medium)
Key CVEs	CVE-2020-8908, CVE-2023-2976
Fix	Upgrade to 32.0.0-jre

CVE-2023-2976 — CVSS 5.5. `TempFileCreator` writes to system temp dir accessible to other local users.

CVE-2020-8908 — CVSS 3.3. Insecure temporary directory creation; local information disclosure.

Outdated Dependencies Summary

Dependency	Current	Latest Stable	Release Gap
<code>org.apache.logging.log4j:log4j-core</code>	2.14.1	2.24.x	~5 years
<code>com.fasterxml.jackson.core:jackson-databind</code>	2.9.8	2.18.8	~6 years
<code>commons-io:commons-io</code>	2.4	2.18.0	~12 years
<code>org.apache.commons:commons-lang3</code>	3.4	3.18.0	~9 years
<code>com.google.guava:guava</code>	24.1.1-jre	33.x	~7 years
<code>mysql:mysql-connector-java</code>	8.0.30	9.x	~3 years

Remediation Priority

1. **Immediate (P0):** Remove `com.fastxml.jackson.core:jackson-databind` — typosquat
 2. **Immediate (P0):** Remove `internal-untrusted-mirror` repository declaration
 3. **This sprint (P1):** Upgrade `log4j-core` + `log4j-api` → 2.17.1 (Log4Shell CVSS 10.0, RCE)
 4. **This sprint (P1):** Upgrade `jackson-databind` → 2.18.8 (55 advisories, CVSS 9.8, RCE)
 5. **Next sprint (P2):** Upgrade `commons-io` → 2.14.0 (CVSS 8.7)
 6. **Next sprint (P2):** Replace `mysql-connector-java` — GPL-2.0 violation + CVE-2023-22102
 7. **Next sprint (P2):** Upgrade `commons-lang3` → 3.18.0; upgrade `guava` → 32.0.0-jre
-

Machine-readable sources: `depscan-report.json` , `depscan-grype-raw.json` . Generated by the *Dependency & Supply-Chain Security Agent* — Stage 1.